

Performance Work Statement (PWS)

IT Support Services

Defense Nuclear Facilities Safety Board (DNFSB)

Date:

Section 1: General

1.1 Introduction

This is a non-personal services contract to provide comprehensive IT support services to the Defense Nuclear Facilities Safety Board (DNFSB). The contractor shall provide personnel, management, and materials necessary to support the agency's IT operations, cybersecurity, compliance, and modernization efforts.

1.1.1 Background

The Defense Nuclear Facilities Safety Board (DNFSB) requires contractor support to maintain a secure, compliant, and audit-ready IT environment. This support is critical to ensuring the confidentiality, integrity, and availability of DNFSB's information systems and data. The contractor will operate under the strategic oversight of the DNFSB Chief Information Officer (CIO) Program Management Office (PMO) and will contribute to broader IT governance, modernization, and risk management initiatives.

Key areas of support include cybersecurity monitoring, audit documentation, insider threat detection, privileged access oversight, and compliance with federal mandates such as the Federal Information Security Modernization Act (FISMA), National Institute of Standards and Technology (NIST) Special Publication (SP) 800-53, and Office of Management and Budget (OMB) guidance. The contractor will play a vital role in strengthening DNFSB's cybersecurity posture and ensuring alignment with evolving federal cybersecurity frameworks.

Operational focus areas include Cybersecurity Governance/RMF, SOC/Incident Response, Vulnerability Management, and audit readiness integration.

1.2 Objective

The contractor shall deliver services that reflect the following performance principles:

- **Quality Execution:** Deliver technically sound, audit-ready outputs that meet or exceed federal compliance standards and DNFSB expectations. All deliverables must be accurate, timely, and fully supportable during audits.

- **Customer Service:** Demonstrate a strong commitment to customer service by collaborating effectively with DNFSB stakeholders, maintaining open communication, and responding promptly to evolving requirements and feedback.
- **Cost Efficiency:** Exercise cost control by maximizing operational efficiency, minimizing rework, and applying best practices in project and resource management to ensure optimal use of government funds.
- **Proactive Risk Management:** Identify, assess, and mitigate cybersecurity and operational risks throughout the contract lifecycle. This includes maintaining situational awareness, adhering to federal cybersecurity frameworks, and supporting continuous improvement in the agency's security posture.

1.3 Scope

The contractor shall provide comprehensive IT and cybersecurity support services across multiple operational and strategic domains. These services include, but are not limited to:

- **Continuous Cybersecurity Monitoring:** Implement and maintain real-time monitoring capabilities to detect, respond to, and mitigate threats.
- **Audit Documentation:** Develop and maintain audit-ready documentation to support internal reviews and external audits.
- **Security Assessment and Authorization (SA&A):** Support the full SA&A lifecycle, including the preparation of system security plans, risk assessments, and associated artifacts.
- **FISMA and CDM Integration:** Facilitate FISMA reporting and integrate relevant data into the Continuous Diagnostics and Mitigation (CDM) dashboard to enhance visibility into the agency's cybersecurity posture.
- **Insider Threat and Privileged Access Management:** Implement mechanisms to detect insider threats and oversee privileged access to mitigate internal risks.
- **Policy and Regulatory Documentation:** Develop and maintain cybersecurity policies and documentation to ensure compliance with federal standards.
- **Incident Response and Threat Intelligence:** Coordinate incident response activities and manage threat intelligence sharing with internal and external stakeholders.
- **Security Training and Awareness:** Develop and deliver role-based security training and awareness programs to ensure personnel are equipped to maintain a secure environment.
- **Configuration Management and Change Control:** Support processes to maintain system integrity, traceability, and accountability.

- **Project and Task Order Management:** Provide PMO services to ensure timely execution, milestone tracking, and performance reporting.
- **Systems Engineering and Enterprise Architecture:** Deliver technical support to align IT infrastructure with DNFSB's mission objectives.
- **Compliance Oversight:** Ensure adherence to IT policies, administrative controls, and applicable regulatory requirements throughout the contract period.

1.3.1 Operational Environment Details

- Total users: 150; Remote 10% / Onsite 90%
- Endpoint inventory: Laptops 182; Desktops 3; Servers 4; Network devices 20; Mobile devices 145; Printers 54
- Database systems: SQL; other databases are connected to cloud-based services
- Systems in scope: 35; Active ATO packages: 35; Estimated SA&A actions per year: 35
- Impact level: Moderate
- Total applications: 45; COTS vs Custom ratio: 100% COTS / 0% Custom
- Primary technology stacks: TBD (to be confirmed with COR and CIO PMO)
- End-of-support applications/platforms: 0
- Endpoint compliance controls: Qualys and Microsoft Intune

1.4 Period of Performance

- **Base Year:** Ten (10) months, commencing on the effective date of award (to be determined) and ending ten (10) months thereafter.
- **Option Years:** Four (4) option periods, each for a duration of twelve (12) months, if exercised by the Government in accordance with FAR 52.217-9, *Option to Extend the Term of the Contract*.

(b) The Government may exercise options by providing written notice to the Contractor within the timeframes specified in the contract. Exercise of options is subject to the availability of funds and continued need for services.

1.5 Place of Performance

DNFSB Headquarters: 625 Indiana Avenue NW, Washington, DC 20004

Telework may be authorized. In-person meetings may be required at no cost to the Government.

Work model: Hybrid—target 70% of contractor staff to be onsite at HQ; specific onsite frequency is position-dependent, with at least one contractor onsite always for Help Desk, System Administration, and Cybersecurity operational coverage. Onsite activities include: physical assistance for IT issues, immediate troubleshooting, onsite equipment management, and hardware replacement.

1.6 Hours of Operation

07:30 AM to 4:30 PM Eastern Time, Monday through Friday, excluding federal holidays. Contractor operational coverage shall be at minimum 7:00 AM to 4:00 PM Eastern Time to ensure overlap with agency hours and continuity of operations.

1.7 Government-Furnished Tools & Integrations

All tools and equipment are Government Furnished (GFE).

Tool inventory:

- SIEM (Microsoft Sentinel)
- EDR (Microsoft Defender)
- PAM (Microsoft Privileged Identity Management)
- GRC (SharePoint-based governance repositories)
- Vulnerability Scanner (Qualys)
- ITSM (ServiceNow)
- MDM (Microsoft Intune)
- CDM (Qualys / CDMaaS DEFEND F for small agencies)
- Mobile Threat Defense (Lookout MTD)
- AI tools (USAi / Microsoft Copilot)

Integrations:

- Existing CDM feeds to Agency & DHS Federal Dashboards
- Microsoft Defender feeds PAC (Persistent Access Capability)

API status:

- Existing; no contractor-built integrations required at award
 - Licensing: FedRAMP-authorized services required where applicable; data export and admin rights handoff to be coordinated during Transition-Out
-

Section 2: Security Requirements

2.1 Personnel Security Vetting

All contractor personnel assigned to this contract must be U.S. citizens. Prior to performance, all personnel shall have or undergo and receive favorable adjudication for one of the following background investigations, based on their role and level of access, as determined by a COR-developed Position Designation Record:

- Tier 1: Non-sensitive Low Risk
- Tier 2: Moderate Risk Public Trust
- Tier 4: High-Risk Public Trust

Contractor personnel must have an appropriate favorably adjudicated background investigation prior to commencing work unless otherwise approved in writing by the Contracting Officer (CO). Contractor personnel must meet Federal fitness requirements for the duration of the contract.

Clearance level:

- Positions are designated up to Tier 2 Public Trust; most roles will require Tier 2 Background investigation
- Service Level Agreement (SLA): ≤15 business days (subject to Security Division processing)

2.2 Privileged User Access

Contractor personnel requiring privileged user access must comply with:

- DoD Directive 8140.01 – Cyberspace Workforce Management
- Completion of DNFSB-specific privileged user training

- Approval by the Contracting Officer's Representative (COR) and DNFSB Chief Information Security Officer (CISO)

Privileged access will not be granted until all requirements are met.

Privileged access SLA: ≤5 business days post-approval and training completion (subject to Security Division processing).

2.3 Physical Security

The contractor shall be responsible for safeguarding all government equipment, information, and property provided for use. At the end of each work period, government facilities, equipment, and materials must be secured.

Contractor personnel shall:

- Wear DNFSB-issued identification badges at all times
- Not share, discuss, or disclose any DNFSB information, including IT system configurations, vulnerabilities, or sensitive data
- Sign a Non-Disclosure Agreement (NDA) prior to accessing DNFSB systems or information

2.4 Information Security

Contractor personnel must protect all sensitive information, including but not limited to:

Controlled Unclassified Information (CUI) e.g.:

- Personally Identifiable Information (PII)
- Official Use Only (OUO)
- Unclassified Controlled Nuclear Information (UCNI)

All information generated in performance of this contract remains the property of the Government.

2.5 Personal Identity Verification (PIV)

In accordance with HSPD-12 and FIPS 201, contractor personnel requiring unescorted physical and/or logical access to DNFSB facilities or systems must:

- Complete a background investigation
- Be issued a PIV credential

- Comply with all DNFSB access control procedures

(Procedural details on custody, incident reporting, renewal, replacement, termination, surrender, and handling of visually distinct badges for short-term contractors remain unchanged and apply as written in the current DNFSB policy set.)

2.6 Use of Government Furnished Equipment (GFE)

The Government will provide laptops and other necessary equipment. Contractor personnel shall:

- Not use GFE for unauthorized purposes
- Report lost or compromised equipment within 2 hours
- Be financially liable for lost or damaged equipment, as determined by the CO

All cybersecurity and IT operations tools are GFE; contractors shall operate within the approved toolset listed in Section 1.7.

2.7 Prohibited Practices

- Use of thumb drives or external storage devices is strictly prohibited
- Sharing of credentials or access tokens is not permitted
- Any security violations must be reported to the COR within 24 hours

Section 3: Task Areas and Requirements

Task 3.1: Artificial Intelligence (AI) Support

Description: Support the integration, monitoring, and risk management of AI technologies within DNFSB systems.

Contractor Responsibilities:

- Monitor AI models for performance and bias
- Conduct AI risk assessments
- Integrate AI capabilities into existing systems

- Update AI-related cybersecurity playbooks
- Provide AI training and awareness materials

Scope includes both AI governance and limited development/integration activities, under DNFSB guardrails: network isolation for AI resources, containerization, and adherence to NIST AI RMF and agency AI policy.

Automation is encouraged for risk triage and workflow orchestration (and approved evidence capture where feasible), including intelligent automation for repetitive workflows and predictive AI for forecasting and selected image/video analysis, subject to privacy, data residency, FedRAMP, and ethics restrictions.

Approved AI tools: USAi and Microsoft Copilot (FedRAMP-authorized configurations).

Deliverables:

- AI Risk Reports (Quarterly)
 - Cybersecurity Playbook Updates (Annually)
 - AI Training Materials (Annually)
 - AI Governance/Development Summary (Annually)
-

Task 3.2: Asset Management

Description: Manage the full lifecycle of IT assets from acquisition to decommissioning.

Contractor Responsibilities:

- Tag and inventory all IT assets
- Configure and deploy new equipment
- Maintain asset tracking systems
- Decommission and dispose of retired assets

Deliverables:

- Monthly Inventory Reports
- Asset Lifecycle Documentation

- Asset compliance reporting leveraging Qualys and Intune (Monthly)
-

Task 3.3: Cybersecurity Operations

Description: Protect and strengthen DNFSB's IT environment through proactive threat monitoring, incident response, risk management, and continuous cybersecurity improvement.

Contractor Responsibilities:

- Lead cybersecurity operations, providing technical direction and oversight to the cybersecurity team
- Develop, implement, and maintain IT security policies, standards, and procedures
- Manage day-to-day cybersecurity operations, including monitoring, threat detection, and response coordination
- Oversee risk management activities, including risk assessments, mitigation planning, and documentation
- Design and support secure IT architectures aligned with organizational goals and compliance requirements
- Drive continuous improvement initiatives to enhance cybersecurity posture and operational efficiency
- Respond to cybersecurity incidents and coordinate incident handling and recovery efforts
- Deploy and manage Security Information and Event Management (SIEM) tools
- Conduct regular vulnerability scans and assessments to identify and remediate security risks
- Maintain and update Plans of Action and Milestones (POA&Ms)
- Ensure compliance with federal cybersecurity frameworks, including NIST RMF & CSF, FISMA, and FedRAMP

Key Deliverables:

- Monthly Cyber Threat Intelligence Reports
- Updated POA&M documentation

- Incident Response Logs
- Cybersecurity Risk Assessment Reports
- IT Security Policy and Procedure Documentation
- Security Architecture Diagrams and Supporting Documentation
- Incident After-Action Reports (AARs)
- Continuous Improvement Plans and Progress Updates
- Team Operations and Leadership Activity Reports
- Compliance Gap Analysis Reports
- Security Awareness and Training Metrics
- CDM Integration Status (Quarterly), including coverage and latency metrics

3.3.1 Continuous Diagnostics and Mitigation (CDM) & Ongoing Authorization

- DNFSB participates in CDM DEFEND F (CDMaaS) for small agencies; CDM coverage for DNFSB GSS is 100%
- CDM latency target: 72 hours; CDM sensors are integrated with the DHS Federal Dashboard
- Integrated feeds: Qualys (agency & federal dashboards), Microsoft Defender (PAC), Lookout Mobile Threat Defense (mobile device feed)
- Success measures: ATO sustainment 100%; evidence freshness $\geq 95\%$
- Risk decision documentation cadence: Annually

Task 3.4: Database Administration

Description: Support the performance, security, and availability of DNFSB databases.

Contractor Responsibilities:

- Perform regular backups
- Optimize database performance

- Apply security patches

Deliverables:

- Backup Reports
 - Optimization Logs
 - Database technology in scope: SQL (with connections to cloud-based services)
-

Task 3.5: Help Desk Services

Description: Provide Tier I and II technical support to DNFSB personnel.

Contractor Responsibilities:

- Respond to user support requests
- Maintain help desk ticketing system
- Deliver user training and onboarding
- Update knowledge base articles
- Coverage: 100% coverage during business hours, with at least one contractor onsite at HQ at all times; minimum coverage 7:00 AM–4:00 PM ET.

Deliverables:

- Monthly Help Desk Metrics
 - Knowledge Base Updates
-

Task 3.6: IT Assessments and Risk Management

Description: Conduct strategic IT assessments and risk evaluations to align with agency goals.

Contractor Responsibilities:

- Perform annual IT assessments

- Identify and document risks
- Support strategic IT planning

Deliverables:

- Risk Register (Quarterly)
 - IT Alignment Briefings (Quarterly)
-

Task 3.7: Information Technology Compliance and Audit Support (New)

Description: Support DNFSB's efforts to achieve and maintain IT compliance and audit readiness through structured documentation, coordination, and continuous improvement activities. This includes preparation for internal and external audits, remediation of findings, and alignment with federal IT regulations and standards.

Contractor Responsibilities:

- Serve as a liaison for IT-related audits (e.g., FISMA, Financial Statements, GAO)
- Manage and track audit requests and data calls
- Coordinate and review audit responses prior to submission
- Document IT-related processes and internal controls
- Support audit walkthroughs, interviews, and documentation reviews
- Develop, implement, and track Corrective Action Plans (CAPs) and POA&Ms
- Ensure alignment with NIST, FISMA, and OMB A-123 requirements
- Submit all PBC evidence to IG/audit staff by the required deadlines

Key Deliverables:

- IT Compliance Status Reports
- Documented Internal Controls and Process Maps

- CAPs and POA&M Status Reports
- Audit Response Packages
- Audit Request Tracking Log
- Audit Walkthrough Support Materials
- Compliance Gap Analysis Reports
- Lessons Learned and Audit Summary Reports
- Updated Audit Readiness Documentation
- Confirmed on-time submission of PBC Evidence Packages

Audit cadence: Annual audits with ad-hoc audits as needed (e.g., FY26 OIG FISMA audit and sensitive data lifecycle audit).

Evidence ownership: Government; POA&M tracking: Contractor (under COR/CISO oversight).

Task 3.8: Mobile Device Management

Description: Manage and secure mobile devices used by DNFSB personnel.

Contractor Responsibilities:

- Enroll and configure mobile devices
- Apply security profiles and policies
- Monitor device compliance
- Tools: Microsoft Intune and Lookout Mobile Threat Defense integrated with agency & federal dashboards

Deliverables:

- Monthly Compliance Logs
- Onboarding Materials

Task 3.9: Network Operations

Description: Maintain and secure DNFSB's network infrastructure.

Contractor Responsibilities:

- Monitor network performance and availability
- Apply patches and updates
- Troubleshoot network issues

Deliverables:

- Monthly Network Health Reports
 - Patch Logs
 - End-of-support platforms: None (EoS count: 0)
-

Task 3.10: Optional Surge Support (if applicable)

Description: Provide additional support during periods of increased demand, such as audits, system migrations, or cybersecurity incidents.

Contractor Responsibilities:

- Respond to surge task orders within 48 hours
- Provide qualified personnel for short-term assignments
- Support extended hours or weekend work as needed

Deliverables:

- Surge Staffing Plan (Upon Request)
- Surge Activity Logs and After-Action Reports

- Surge triggers include audit windows, major incidents, and migrations; ticket spike thresholds to be defined with COR (TBD)
 - Notice period: 3–5 days (to be set per surge task order). Pricing via pre-priced CLINs or ad hoc, as directed by CO.
-

Task 3.11: Program and Contract Management

Description: Oversee project milestones, risks, and coordination with government stakeholders.

Contractor Responsibilities:

- Track project milestones and deliverables
- Manage risks and issues
- Coordinate with the COR and stakeholders

Deliverables:

- Monthly Status Reports
 - Program Dashboards
-

Task 3.12: SharePoint Development and Administration

Description: Manage DNFSB's SharePoint environment for collaboration and content management.

Contractor Responsibilities:

- Configure and maintain SharePoint sites
- Manage permissions and workflows
- Support content governance

Deliverables:

- Monthly Usage Reports
- Governance Documentation

Task 3.13: System and Server Administration

Description: Ensure the availability, security, and performance of DNFSB systems and servers. Endpoint compliance tooling: Qualys and Intune.

Contractor Responsibilities:

- Monitor system health and performance
- Patch vulnerabilities
- Manage user access and backups

Deliverables:

- System Health Reports
 - Backup Logs
 - Patch Logs
-

Task 3.14: Technical Policy Writing

Description: Develop and maintain IT policies and user documentation. Policies will align with NIST RMF, NIST CSF 2.0, OMB A-123/A-130, and FISCAM.

Contractor Responsibilities:

- Draft and update IT policies
- Create user guides and SOPs
- Ensure alignment with federal standards

Deliverables:

- Updated Policies (Quarterly)
 - User Guides
-

Task 3.15: Training and Knowledge Transfer

Description: Provide training and ensure knowledge transfer to DNFSB personnel.

Contractor Responsibilities:

- Develop and deliver IT training sessions
- Maintain training records
- Support knowledge transfer during transitions

Deliverables:

- Training Materials
 - Attendance Logs
 - Annual completion targets: 100% of required role-based training
-

Task 3.16: Web Development and Administration

Description: Maintain DNFSB's public-facing website and ensure compliance with accessibility and security standards.

Contractor Responsibilities:

- Update website content and structure
- Ensure Section 508 compliance
- Monitor website performance and security

Deliverables:

- Website Performance Reports
 - Accessibility Logs
-

Task 3.17: Microsoft 365 E5/G5 Security & Compliance: Purview DLP & Defender

Description

The Contractor shall design, deploy, document, tune, and operationally maintain Microsoft Purview Data Loss Prevention (DLP) and the Microsoft Defender security suite across the DNFSB Microsoft 365 E5/G5 tenant. This includes establishing DLP policy intent statements, creating policy configurations aligned to best practices, implementing data exfiltration safeguards, establishing operational metrics, and integrating DLP and Defender capabilities into DNFSB's cybersecurity governance framework. Policies and configurations shall protect CUI, PII, and mission-sensitive data, while aligning to federal requirements and DNFSB risk tolerance.

Contractor Responsibilities

- **Policy Design & Documentation:** Draft **policy intent statements** and map them to concrete DLP configurations (locations, conditions, actions, exceptions). Maintain **version-controlled documentation** of all policy settings and changes.
- **SITs/EDM/Fingerprinting:** Use Microsoft **built-in Sensitive Information Types (SITs)**; create **custom SITs** and **Exact Data Match (EDM)** or document fingerprinting to detect DNFSB-specific data.
- **Email DLP:** Detect sensitive content in **subject, body, and attachments**; apply **block, encrypt (OME), warn/override with justification, or audit** per risk tolerance and recipient context (internal vs. external/allowed domains).
- **Alerting & Incident Workflow:** Configure alerts and **incident triage workflows** in Microsoft Defender and Microsoft Purview; tune rules using **Activity Explorer** and alert analytics.
- **Endpoint DLP:** Implement controls to detect/restrict uploads to external websites/cloud apps from onboarded DNFSB devices, including **copy/paste, clipboard, print, and USB/removable media** restrictions; validate enforcement coverage.
- **Browser & Domain Restrictions:** Define approved browsers (e.g., Edge; Chrome via Purview extension) and configure **Sensitive Service Domain Groups** to block uploads to consumer file-sharing and AI/chat sites as directed by DNFSB.
- **Insider Risk & Adaptive Protection:** Propose Insider Risk Management policies that correlate signals for data leakage; where appropriate, leverage **Adaptive Protection** to dynamically scope stricter DLP actions to high-risk users.
- **Exfiltration Tests (SC-7(10)):** Conduct periodic **exfiltration validation tests** (email and web uploads) at agency-defined frequency, aligned to **NIST SP 800-53 Rev.5 SC-7(10)**.
- **Monthly Metrics & Tuning:** Produce **monthly reports** covering violations, false positives, user overrides, and MTTR; use Activity Explorer and alert analytics to justify tuning and demonstrate risk reduction.

- **CASB Integration (MDCA):** Integrate **Microsoft Defender for Cloud Apps** with Purview to apply session controls (block download/copy/print on unmanaged devices) and scope DLP to SaaS instances.

Deliverables

1. **DLP Design & Configuration Document** (intent statements; SITs/EDM definitions; rule logic; actions; exceptions; scoping; platform limits).
 2. **Deployed DLP Policies** across Exchange, SharePoint/OneDrive, Teams, Endpoint/Web; **Endpoint onboarding records**; **MDCA** integration/config for non-Microsoft apps; and **domain/browser restriction sets**.
 3. **Exfiltration Test Plans & Quarterly Results** (email and web uploads; tuning actions).
 4. **Monthly KPI Reports** (violations, false positives, overrides, MTTR) with tuning notes based on Activity Explorer and alert analytics.
 5. **Playbooks & Knowledge Transfer** (policy naming conventions, workload scoping, exception handling, incident response; enforcement engine differences).
-

Section 4: Deliverables and Performance Standards

4.1 General Requirements

The contractor shall provide all deliverables in electronic format unless otherwise specified by the COR. All deliverables must be:

- Timely
- Accurate
- Complete
- Professionally formatted
- Aligned with applicable federal standards (e.g., NIST, FISMA, OMB A-123)

The COR will review all deliverables for quality and may request revisions. The contractor shall make corrections at no additional cost to the Government.

Transition-In reporting cadence: Weekly during Transition-In and Stabilization; steady-state reporting per monthly and quarterly cycles as specified in Sections 4.2 and 6.

4.2 Recurring Deliverables

Task Area	Deliverable	Frequency
AI Support	Risk Reports, Playbook	Quarterly/Annually
Cybersecurity	Threat Reports, POA&Ms	Monthly
Cybersecurity	CDM Integration Status	Quarterly
Asset Mgmt	Inventory Reports	Monthly
Asset Mgmt	Compliance reporting via Qualys/Intune	Monthly
Help Desk	Metrics, KB Updates	Monthly
Assessments	Risk Register, Briefings	Quarterly
Mobile Devices	Compliance Logs	Monthly
Network Ops	Health Reports	Monthly
Program Mgmt	Status Reports	Monthly
Program Mgmt	Transition-In Reports	Weekly
Program Mgmt	Performance Review Decks	Quarterly
System Admin	Patch Logs, Backups	Monthly
Policy Writing	Updated Docs	Quarterly
SharePoint	Usage Reports	Monthly
Database	Backup Logs	Monthly
Web Dev	Performance Logs	Monthly

Training	Materials, Logs	Annually
Data Protection (Task 3.17)	DLP Monthly KPI Report (violations, false positives, overrides, MTTR, tuning notes)	Monthly
Data Protection (Task 3.17)	Exfiltration Test Results (SC-7(10)) – email/web upload validation	Quarterly
Data Protection (Task 3.17)	Endpoint DLP Onboarding & Enforcement Record	Monthly
Data Protection (Task 3.17)	MDCA Session Control Validation Report	Quarterly
Data Protection (Task 3.17)	Browser/Domain Restriction Set Updates (approved browsers + sensitive domain groups)	Quarterly

4.3 Performance Standards

Area	Standard	AQL	Surveillance
Timeliness	On-time delivery	98%	100% Inspection
Accuracy	Error-free	98%	Sampling
Incident Response	2-hour response	100%	Log Review
Compliance	NIST/FISMA/FedRAMP	100%	Audit
Training	Annual completion	100%	Verification
Knowledge Transfer	Docs & sessions	100%	COR Review
ATO Sustainment	ATO sustainment	100%	Audit
Evidence Freshness	≥95% evidence freshness	95%	Audit

CDM Coverage	≥95% coverage (DNFSB GSS currently 100%)	100%	Dashboard Review
Patch SLAs	Critical ≤15d; High ≤30d; Moderate ≤60d; Low ≤90d	100%	Vulnerability Scan Logs
Secure Baseline	≥95% compliance to secure baseline	95%	Configuration Audit
ITSM Metrics	ASA ≤60s; FCR ≥70–80%; MTTR by tier; CSAT ≥4.5/5	95%	Ticket System Reports
IR Metrics	Triage ≤15m; Containment ≤4h	100%	Incident Logs
Automation Adoption	≥70% evidence automated by Month 9; ≥20% manual effort reduction by Year 1	70%	COR Review
Reporting Cadence	Weekly (Transition-In), Monthly, Quarterly	100%	COR Review

4.4 Quality Assurance

Performance will be monitored via a QASP and regular COR reviews.

Success measures include FISMA audit pass/favorable results and achievement of Annual Workplan outcomes.

(Reserved sections and placeholder tables under 4.4 may be cleaned up during editorial review; no change to intent.)

4.4 Quality Assurance Surveillance

The Government will evaluate contractor performance using a **Quality Assurance Surveillance Plan (QASP)**. The COR will:

- Monitor deliverables and task execution

- Conduct periodic performance reviews
- Document deficiencies and request corrective actions
- Provide feedback to the Contracting Officer

Quarterly Performance Review Meetings are required (see Section 6.3).

Section 5: Key Personnel and Qualifications

5.1 Key Personnel Designation

The contractor shall identify and assign qualified personnel to serve in key roles critical to the successful execution of this contract. At a minimum, the following positions are designated as Key Personnel:

- Program Manager
- Cybersecurity Lead
- AI/Advanced Technology Lead
- Help Desk Manager
- System Administrator Lead
- Network Operations Lead
- Compliance and Risk Analyst
- Technical Policy Writer

The contractor shall notify the CO and COR in writing within five (5) business days of any changes to key personnel and submit proposed replacements for approval. Resumes for key personnel are required at proposal/award; Government interview rights: No.

5.2 General Qualifications

All contractor personnel shall possess the necessary education, experience, and certifications to perform assigned duties. (Roles and minimum qualifications as in current PWS remain unchanged.)

5.2.1 Required Technical Knowledge & Experience (Microsoft 365 Security & Compliance) (New)

Personnel performing cybersecurity, threat detection, data loss prevention, or information protection tasks shall demonstrate hands-on experience with:

- Microsoft Defender for Endpoint, Identity, Office 365, Cloud Apps (CASB)
- Microsoft Sentinel
- Microsoft Purview Compliance portal
- Microsoft Purview DLP (Exchange, SharePoint/OneDrive, Teams, Endpoint)
- Microsoft Purview Information Protection (Sensitivity Labels, encryption, auto-labeling)
- Insider Risk Management and Adaptive Protection
- Audit, eDiscovery (Standard/Premium), and compliance analytics
- Awareness of feature differences across **Commercial, GCC, GCC High, and DoD** environments and licensing prerequisites for advanced E5/G5 features
- Compliance requirements for handling **CUI** and **PII**

5.2.2 Certification & Training Requirements (New)

Proposed personnel shall possess at least one of the following Microsoft certifications (or equivalent knowledge demonstrated through documented experience):

- Microsoft Certified: Cybersecurity Architect Expert (SC-100)
- Microsoft Certified: Security Operations Analyst Associate (SC-200)
- Microsoft Certified: Identity and Access Administrator Associate (SC-300)
- Microsoft Certified: Information Protection Administrator Associate (SC-400)
- Microsoft 365 Certified: Enterprise Administrator Expert (MS-102 era)
- Microsoft Certified: Azure Security Engineer Associate

The Contractor shall provide evidence that key personnel have completed Microsoft security and compliance technical training, either through official Microsoft Learn tracks or equivalent vendor-provided courses.

5.3 Personnel Substitution (Updated)

No substitution or replacement of key cybersecurity personnel (as designated in Section 5.1 and assigned to Task 3.17) shall occur without prior written Agency approval. Any proposed replacement must be **equally or better-qualified**, with documented experience designing, configuring, tuning, deploying, and operationally maintaining Microsoft Purview DLP and Microsoft Defender capabilities in a Government Community Cloud (GCC/GCC High/DoD) tenant. The Agency reserves the right to interview proposed replacements prior to approval.

Section 6: Contract Management and Reporting

6.1 Contract Kick-Off Meeting

Within ten (10) business days of award, the contractor shall coordinate with the COR to conduct a formal kick-off meeting. (Agenda, minutes, transition cadence, and artifacts remain as written.)

6.2 Monthly Status Reports

Submit by the 10th business day of each month, covering work performed, deliverable status, issues/resolutions, risks/mitigations, staffing updates, and hours by labor category (if required). Weekly reporting required during Transition-In/Stabilization; quarterly performance review materials provided.

6.3 Quarterly Performance Reviews

Participate in Quarterly Performance Review Meetings to assess performance against PWS and QASP; discuss deliverables, timeliness, and quality; address deficiencies; identify improvement opportunities.

6.4 Risk and Issue Management

Maintain a Risk and Issue Log updated monthly and submitted with status reports (description, impact, owner, mitigation, status, timeline).

6.5 Communication Protocols

Designate a primary POC (Program Manager); respond to Government inquiries within one (1) business day; notify COR of scope concerns or potential delays immediately; use secure, Government-approved channels for sensitive information. Evidence ownership resides with the Government; POA&M tracking responsibilities lie with the Contractor (under COR/CISO oversight).

6.6 Transition Planning

6.6.1 Transition-In: Support smooth transition from incumbent contractor.

6.6.2 Transition-Out: Submit a Transition-Out Plan 45 days prior to contract expiration/termination (knowledge transfer schedule, inventory of deliverables/docs, offboarding, return of GFE, final status report). CDM, ITSM, and security tool admin rights will be handed off per CO/COR direction; data export formats to be agreed upon (TBD).

Section 7: Applicable Regulations and References

7.1 Federal Laws and Executive Orders

FISMA; Privacy Act; Clinger-Cohen Act; E-Government Act; EO 14028; EO 13800.

7.2 OMB Guidance

OMB Circular A-123; A-130; A-136; M-19-26 (TIC); M-21-31 (logging).

7.3 NIST Publications

NIST SP 800-37; 800-53; 800-171; Cybersecurity Framework (CSF) 2.0; AI RMF 1.0; SP 800-61.

7.4 GAO Standards

GAO Green Book; GAO FISCAM.

7.5 Other References

FedRAMP; DOE/DNFSB IT Security directives; HSPD-12; FAR Part 37.2.

7.6 Microsoft References (Implementation Guidance) (New)

- Microsoft Purview DLP Policy Reference & Design/Deployment Best Practices
- Sensitive Information Types (Built-In & Custom)
- Exact Data Match (EDM)
- Endpoint DLP Settings & Scenarios

- Defender for Cloud Apps (CASB) Session Controls
- Insider Risk Management & Adaptive Protection

7.7 NIST Control Reference (Exfiltration Testing) (New)

- NIST SP 800-53 Rev. 5 **SC-7(10) – Prevent Exfiltration**
-

DRAFT

APPENDIX A – SECTION L: Offeror Instructions & Experience Documentation

L.1 Key Personnel Experience Documentation

Provide résumés for all key personnel demonstrating **≥3 years' experience** configuring/administering Microsoft 365 E5/G5 security & compliance tools in enterprise environments.

L.2 Prior Project Experience (Last 5 Years – Two Examples)

Submit at least **two** examples where your company successfully implemented Microsoft Defender and Microsoft Purview capabilities supporting:

- Protection of sensitive information (CUI, PII, PHI, mission-specific data)
- Deployment and tuning of advanced DLP policies
- Endpoint and identity threat protection
- Cloud app governance and session control
- Insider risk monitoring and adaptive protection

L.3 Methodology (Government Tenant Operationalization)

Describe methodology for securely implementing and operationalizing Microsoft Defender & Purview within a government tenant, including:

- Governance processes and change management

- Testing & validation procedures
 - Continuous monitoring and tuning practices
-

DRAFT

APPENDIX B – SECTION M: Evaluation Criteria

Proposals will be evaluated on multiple factors to ensure the best overall value for the government. As part of this assessment, the government will consider the offeror's depth and relevance of experience with Microsoft Defender and Microsoft Purview in a government M365 E5/G5 environment. This experience will be evaluated in conjunction with other technical, management, and performance considerations and will not serve as the sole basis for determination:

- Demonstrated success in securing PII and sensitive agency information
- Ability to deploy, configure, and tune Purview DLP across workloads
- Proficiency in threat detection, incident response, and endpoint protection
- Understanding of GCC-specific considerations and limitations

Higher ratings where candidates demonstrate advanced certifications, extensive hands-on experience, or documented success implementing multi-layered security architectures using Defender, Purview, and complementary tools.

APPENDIX C – Self-Certification Checklist

Instructions

Complete all items. Where marked “Provide details,” add a short narrative (3–5 sentences). The Agency may request interviews or demonstrations to validate any item. By signing, the Offeror attests that all statements are true and that the Agency may verify them.

A. Tenant, Licensing, and Cloud Instance

☐ We have implemented and operated Microsoft 365 security & compliance features in **GCC/GCC High** and understand capability variances vs. commercial tenants.

Provide details: _____

☐ We understand M365 E5/G5 licensing coverage for advanced Purview DLP, Insider Risk, Audit/eDiscovery, and Microsoft Defender components (Endpoint, Identity, Office 365, Cloud Apps) and can advise on prerequisites.

Provide details: _____

B. Role-Based Access & Governance

☐ Our staff use least-privileged roles (Compliance Administrator, Compliance Data Administrator, Information Protection Admin, Security Administrator) for DLP/information protection; Global Administrator only where necessary.

Provide details: _____

☐ We maintain change control, pilot phasing (**audit → warn → block**), and rollback plans for DLP/security deployments in alignment with Microsoft guidance.

Provide details: _____

C. Microsoft Purview — Data Protection

☐ We design, configure, and deploy Purview DLP policies across **Exchange Online**, SharePoint/OneDrive, Teams (chat/messages), and Endpoint, with documented policy intent statements and rules (conditions, actions, exceptions).

Provide details: _____

☐ We implement Sensitive Information Types (SITs) using Microsoft built-in detectors and create custom SITs/EDM/document fingerprinting as needed to protect agency-specific PII/sensitive data.

Provide examples: _____

☐ Our designs respect platform constraints (policy/rule limits, scan limits) to ensure reliability and scalability in large tenants.

Provide details: _____

☐ We configure Policy Tips (and “wait-on-send” dialogs where supported) to reduce accidental leakage and improve Outlook user experience.

Provide details: _____

D. Exchange Online — Email Exfiltration Controls

☐ We have implemented outbound email controls that detect sensitive content in subject/body/attachments and apply block, encryption (OME), warn/override, or audit based on recipient context and agency policy.

Provide examples: _____

E. Endpoint DLP — Devices & Browser/Domain Controls

☐ We have onboarded Windows 10/11 (and macOS as applicable) to Endpoint DLP and validated connectivity to cloud DLP services.

Provide details: _____

☐ We configure cross-platform protections and document offline enforcement behavior.

Provide details: _____

☐ We implement Browser & Domain restrictions to sensitive data, defining allowed browsers and sensitive service domain groups (e.g., consumer file-sharing/AI sites) to block uploads of sensitive content.

Provide examples: _____

F. Non-Microsoft SaaS — Defender for Cloud Apps (CASB)

☐ We integrate MDCA with Purview, connect third-party apps (e.g., Box, Dropbox, Google Workspace, Salesforce), and scope DLP policies to Instances with appropriate session controls.

Provide examples: _____

☐ We design session control policies (e.g., block download, restrict copy/paste/print on unmanaged devices) for targeted SaaS apps via MDCA Conditional Access App Control.

Provide details: _____

G. Insider Risk & Adaptive Protection (Government Clouds)

☐ We configure Insider Risk Management policies to correlate signals for data leakage/IP theft and manage cases with privacy safeguards (pseudonymization, RBAC).

Provide examples: _____

☐ Where requested, we enable Adaptive Protection integration with DLP in GCC/GCC High/DoD, dynamically scoping stricter actions for high-risk users; rollout notes and controls documented.

Provide details: _____

H. Security Operations — Microsoft Defender

☐ We operate Defender for Endpoint for threat detection, vulnerability exposure scoring, device posture, alert triage, investigation, and live response, including integration to SIEM (Sentinel) where applicable.

Provide examples: _____

☐ We deploy and manage Defender for Identity, Defender for Office 365, and Defender for Cloud Apps to protect identities, email/collaboration, and SaaS usage, coordinating with Purview DLP for comprehensive controls.

Provide details: _____

I. Testing, Metrics, and Compliance

☐ We conduct periodic exfiltration tests (sending sensitive data via email; attempting uploads to external sites) and report outcomes aligned with NIST SP 800-53 Rev.5 SC-7(10) – Prevent Exfiltration.

Provide sample reports: _____

☐ We deliver monthly KPIs (violations, false positives, user overrides, MTTR) and use Activity Explorer/alerts to justify policy tuning.

Provide a recent KPI excerpt: _____

☐ We integrate Sensitivity Labels with DLP actions and, for connected SaaS, apply labels via MDCA governance to matched files, demonstrating visibility of classified assets.

Provide examples: _____

J. Documentation & Knowledge Transfer

☐ We provide playbooks documenting policy naming conventions, workload scoping, exception handling, incident response, and acknowledge distinct enforcement engines (Exchange, SharePoint/OneDrive, Teams, Endpoint/Web).

Provide a sample TOC: _____

☐ We deliver user education materials explaining DLP notifications and secure alternatives (encrypted email, secure sharing links), including Outlook support nuances.

Provide a sample: _____

Certification Statement

By checking the boxes above and signing below, the Offeror certifies that:

- All statements are true and accurate;
- The Agency may verify any statement via interview, demonstration, environment review, or past-performance checks;
- The Offeror will provide equally or better-qualified replacements for proposed key personnel, subject to Agency approval;
- The Offeror understands that misrepresentation may be grounds for disqualification or termination.

Offeror Name: _____

Authorized Representative (Name/Title): _____

Signature: _____ **Date:** ____ / ____ / 20____

Contact Email/Phone: _____

APPENDIX D – Section L/M Crosswalk & Evaluator Scoring Rubric

D.1 L/M ⇔ PWS Crosswalk (Examples)

- **L-A (Tenant/Licensing/Cloud)** → **PWS 3.17** + **Section 5.2.1/5.2.2** (E5/G5 awareness; GCC/GCC High/DoD differences)
- **L-B (RBAC & Governance)** → **PWS 3.17** (policy docs/version control; audit→warn→block; rollback) + **Section 6.4**
- **L-C/D/E (Purview DLP; Exchange; Endpoint/Browser/Domain)** → **PWS 3.17** responsibilities & **Section 4.2** additions
- **L-F (MDCA / CASB)** → **PWS 3.17** CASB integration
- **L-G (Insider Risk & Adaptive)** → **PWS 3.17** (IRM & Adaptive Protection)
- **L-H (Security Ops — Defender)** → **PWS 3.3** + **PWS 3.17** linkages
- **L-I (Testing/Metrics/Compliance)** → **PWS 3.17** (SC-7(10) exfil tests) + **Section 4.2** new rows
- **L-J (Docs & KT)** → **PWS 3.17** (playbooks/KT) + **PWS 3.15 Training**

D.2 Evaluator Scoring Rubric (Illustrative Weights)

Criterion	Weight	Indicators of Strength
Purview DLP across workloads	25%	Intent→config mapping; SITs+EDM; monthly KPIs; exfil tests; tuning cycles
Defender stack + Sentinel	20%	Runbooks, triage workflows, SIEM integration use cases
Insider Risk & Adaptive Protection	15%	IRM policies; Adaptive Protection scoping; rollout notes

Criterion	Weight	Indicators of Strength
GCC/GCC High/DoD awareness & licensing	15%	Clear feature differences, compliance handling for CUI/PII
Email exfil protection	10%	Subject/body/attachments; domain scoping; Policy Tips/wait-on-send
Endpoint & Browser/Domain controls	10%	Copy/paste/print/USB restrictions; sensitive domain groups; approved browsers
Documentation & Knowledge Transfer	5%	Playbooks, naming conventions, exception handling, user education